

Zweiter Faktor – doppelt Ärger?

Thorsten Butz

Abstrakt

Zwei-Faktor-Authentisierung (2FA) oder allgemein Multifaktor-Authentisierung (MFA) ist allgegenwärtig - zumindest die Forderung nach derselben.

So erzwingt Microsoft für seine Abonnement-Kunden (Microsoft 365) den zweiten Faktor seit dem Jahreswechsel, was laut Gerüchten manchem IT-Verantwortlichen graue Haare wachsen lässt. Seien wir ehrlich: hätten Admins in den zurückliegenden Jahren nicht oftmals die Passwörter der Mitarbeiter im Kopf gehabt, so wäre manches IT-Zipperlein nicht so schnell und unkompliziert behoben worden. Aber: die Zeiten ändern sich!

Von TOTP bis Passkey, von Fido 2 Token bis QRCode - Thorsten Butz stellt kurzweilig und pragmatisch Alltagsprobleme und - oftmals überraschend einfache - Lösungsansätze vor.

- Wie stellt man den zweiten Faktor wieder her, wenn ein Mitarbeiter das Telefon verliert?
- Sollte man doch besser ein Fido 2 security token anschaffen - und wenn ja: wie viele?
- Und welche der zahlreichen gleichnamigen "Authenticator" apps ist die "richtige"?

Unser Tipp: warten Sie mit dem Praxistest besser nicht bis zur ersten "echten" Wiederherstellung.

20
17



Thorsten Butz

 thorsten-butz.de

 @thorsten.butz.io

 @thorstenbutz

 slidingwindows.de

20
25

\$URI

Homepage // thorsten-butz.de

Podcast // slidingwindows.de

Github // github.com/thorstenbutz

Vimeo // vimeo.com/thorstenbutz

Sessionize // sessionize.com/thorstenbutz

\$SOCIAL

LinkedIn // thorstenbutz

BlueSky // @thorsten.butz.io

Mastodon // @thorstenbutz@twit.social

Xtwitter // @thorstenbutz

Pwned Passwords

Check if your password has appeared in known data breaches



Oh no — pwned!

This password has been seen **391,708** times before in data breaches!

This password has previously appeared in a data breach and should never be used. If you've ever used it anywhere before, change it immediately!

```
#####
## Troy Hunts: Have I been pwned?
## https://haveibeenpwned.com/API/v3#SearchingPwnedPasswordsByRange
## RegEx: Split after 5 characters from the beginning, e.g.
## 'ABCDE123' -split '(?<=^.{5})'
#####
```

```
$password = 'Pa$$w0rd'
```

```
$hash = (Get-FileHash -A 'SHA1' -InputStream (
    [IO.MemoryStream]::new([Text.Encoding]::UTF8.GetBytes($password)))
).Hash
```

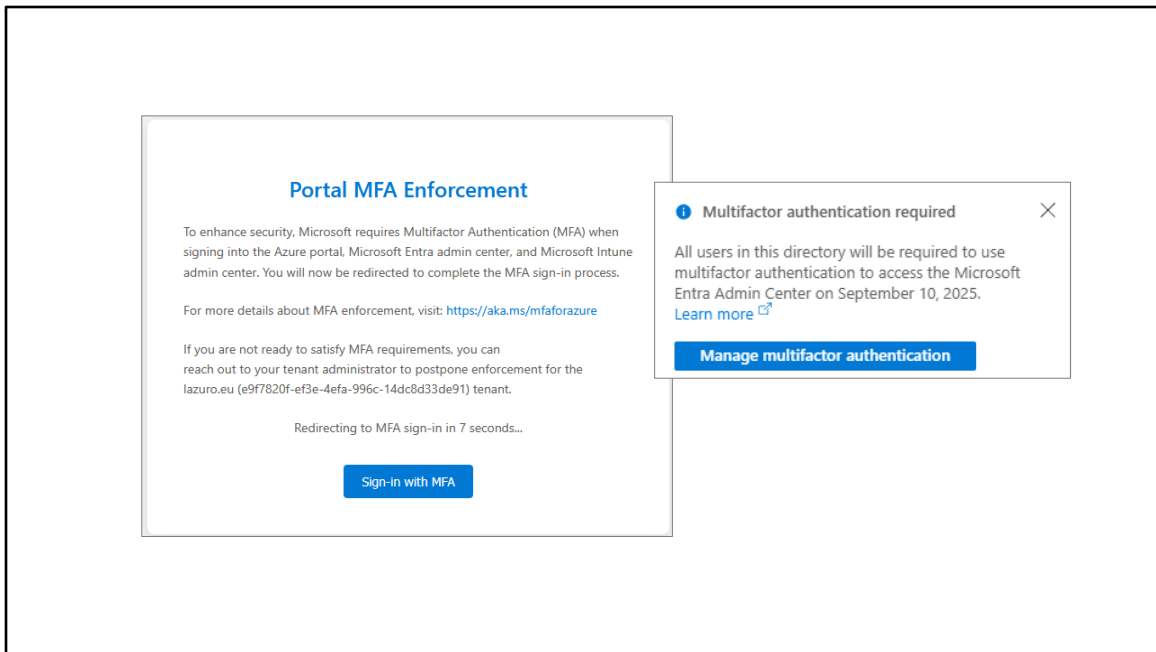
```
$splitA,$splitB = $hash -split '(?<=^.{5})'
```

```
$Uri = "https://api.pwnedpasswords.com/range/$splitA"
(((Invoke-RestMethod -UseBasicParsing -Uri $Uri) -split
    '\r\n' -like "$splitB*") -split ':')[-1]
```

A	<pre>\$password = 'Lingen' \$hash = (Get-FileHash -A 'SHA1' -InputStream ([IO.MemoryStream]::new([Text.Encoding]::UTF8.GetBytes(\$password))) >>).Hash</pre> <pre>\$hash => 71BD0D9D2C2581B9CB253854086D624E5B64E325</pre>
B	<pre>\$splitA,\$splitB = \$hash -split '(?<=^.{5})'</pre> <pre>\$splitA => 71BD0 \$splitB => D9D2C2581B9CB253854086D624E5B64E325</pre>
C	<pre>\$Uri = "https://api.pwnedpasswords.com/range/\$splitA" (((Invoke-RestMethod -UseBasicParsing -Uri \$Uri) -split '\r\n' -like "\$splitB*") -split ':')[-1]</pre>

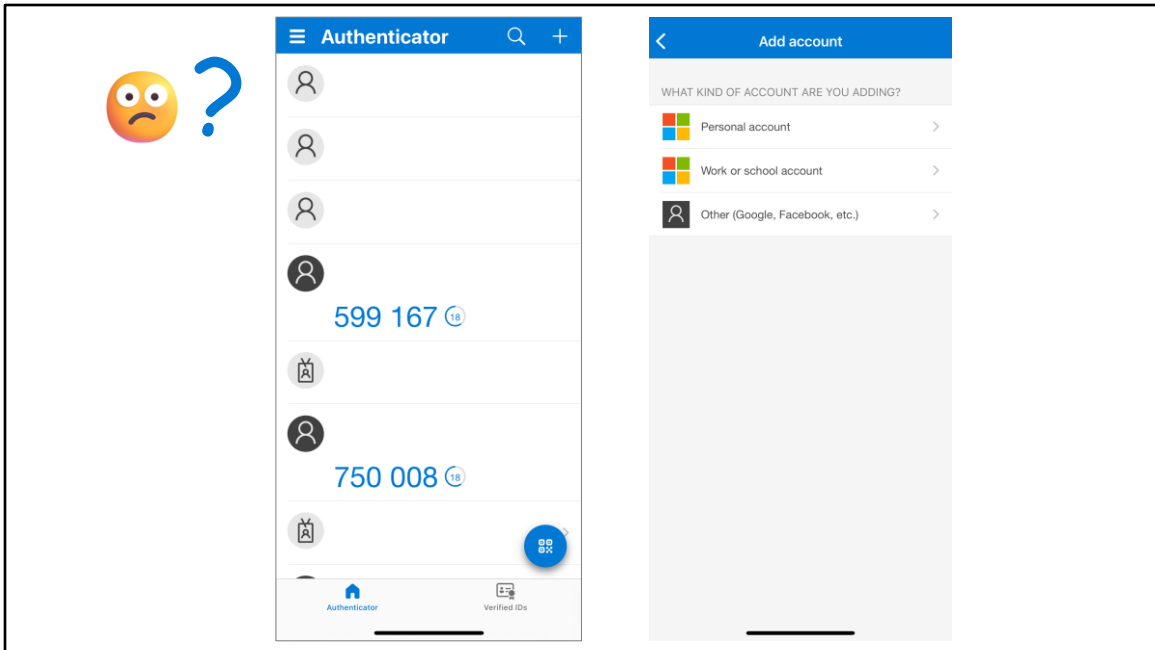
Das Script hat einen entscheidenden Vorteil gegenüber der Eingabe eines Passworts (oder anderer sensibler Daten) auf der Webseite von Troy Hunt (haveibeenpwned.com): Man kann detailliert nachvollziehen, dass der Suchbegriff (\$password) gar nicht an die REST-API übertragen wird.

- In Teil A wird der Suchbegriff (\$password) gehasht.
- In Teil B wird der Suchbegriff in zwei Teile aufgeteilt, der erste Teil (\$splitA) besteht aus den ersten 5 Zeichen des Hash.
- In Teil C wird lediglich dieser erste Teil (\$splitA) an die API von haveibeenpwned.com übertragen.
Die API liefert alle bekannten Treffer zurück, deren Hashwert in den ersten 5 Zeichen mit unserer Suche übereinstimmen.
Im letzten Schritt (letzte Zeile des Scripts) werden die übermittelten Hashwerte mit unserem Hash verglichen. Sollte es eine Übereinstimmung geben, wird die Anzahl der Quellen genannt, in denen dieses Passwort zu finden war.



Planning for mandatory multifactor authentication for Azure and other admin portals

<https://learn.microsoft.com/en-us/entra/identity/authentication/concept-mandatory-multifactor-authentication?tabs=dotnet>



Markus Michalski hat den Begriff "**sad cyclops**" (trauriger Zyklop) für die unterschiedlichen icons in Microsofts authenticator app.

<https://bsky.app/profile/markusmichalski.bsky.social/post/3lyiy6xgmzc27>

Man kann daraus ein Quiz machen: Welches Symbol steht für welchen Kontotyp bzw. für welches Authentisierungsverfahren?

<https://mysignins.microsoft.com/security-info>

Add a sign-in method

- Passkey in Microsoft Authenticator**
Sign in with your face, fingerprint, PIN
- Security key**
Sign in using a USB, Bluetooth, or NFC device
- Microsoft Authenticator**
Approve sign-in requests or use one-time codes
- Hardware token**
Sign in with a code from a hardware token
- Phone**
Get a call or text to sign in with a code
- Alternate phone**
Get a call to sign in with a code
- Office phone**
Get a call to sign in with a code
- App password**
Use this to sign in to a specific app that requires a password

Need more info? [Learn more about each method.](#)



<https://myaccount.google.com/security>

How you sign in to Google

- 2-Step Verification**
- Passkeys and security keys**
- Password**
- Skip password when possible**
- Authenticator**
- Google prompt**
- 2-Step Verification phones**
- Recovery phone**
- Recovery email**
- Security question**



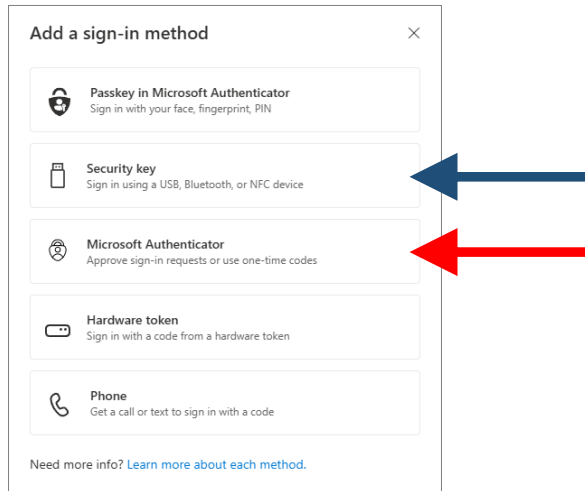
Links:

<https://mysignins.microsoft.com/>

Rechts:

<https://myaccount.google.com/security>

EntraID account



Microsoft Authenticator (unterer Pfeil) => **Demo 1**

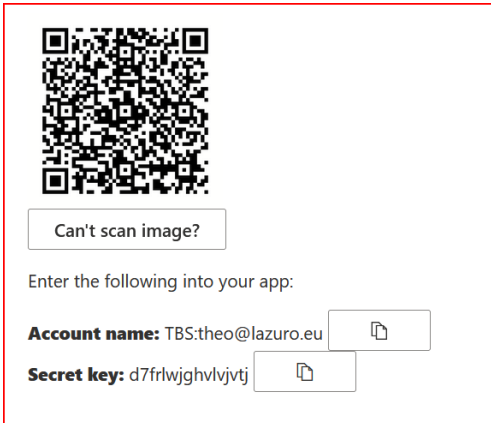
Dieses Verfahren steht de-facto für TOTP, die Bezeichnung ist irreführend.

Security key (oberer Pfeil) => **Demo 2**

Fido2 token (zum Beispiel: <https://token2.com/>)

DEMO 1

TOTP seed ("shared secret")



- TOTP: Time-Based One-Time Password Algorithm
RFC 6238

Das gemeinsame Geheimnis, auch SEED genannt, kann abgespeichert und beliebig oft mit (verschiedenen) TOTP clients zur Berechnung des Authentifizierungscodes verwendet werden.

Das von mir ebenfalls verwendete OTP-Modul für die PowerShell findet man in der PowerShell Gallery.

<https://www.powershellgallery.com/packages/OTP>

Auf der Projektseite finden sich weiterführende Erklärungen zum Protokoll und zu meiner Implementierung:

<https://github.com/thorstenbutz/otp>

TOTP clients

- [Google](#) Authenticator
- [Microsoft](#) Authenticator
- Authy (Twilio Authy)
- Proton Authenticator
- Duo Mobile
- FreeOTP ([Red Hat](#))
-

```
# > Install-Module -Name OTP
# > Get-Command -Module OTP
```

CommandType	Name	Version	Source
Function	Get-OTPCode	0.1.1	OTP
Function	New-OTPSecret	0.1.1	OTP
Function	Read-OTPQRCode	0.1.1	OTP

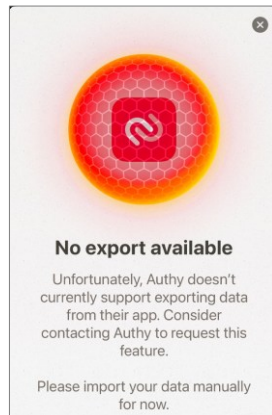
```
# > Read-OTPQRCode -Path .\theo.png | Get-OTPCode
```

Code	Algorithm	HashAlgorithm	Seed
727318	TOTP	SHA1	D7FRLWJGHVLVJVTJ

Es mangelt nicht an TOTP clients ...

TOTP clients: Vorsicht Falle!

MIND THE GAP

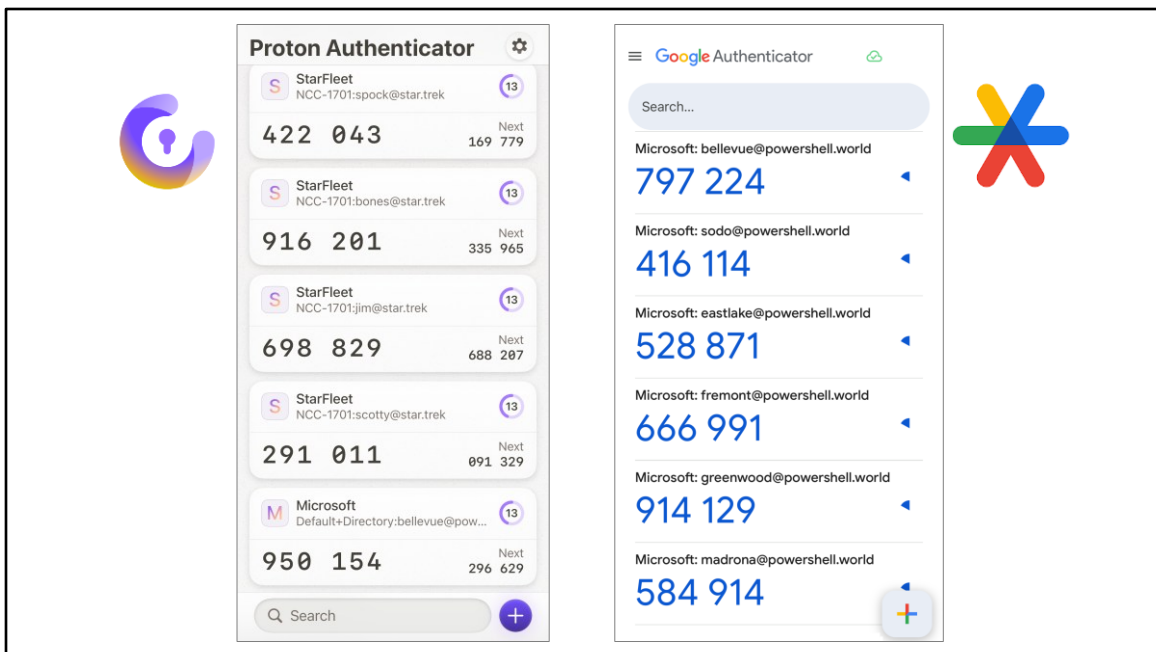


Authy



Microsoft Authenticator

Meines Erachtens ist eine fehlende oder mangelhafte Exportfunktion der entscheidene Punkt, sich Gegen einen bestimmten TOTP-Client zu entscheiden. Die Screenshots sind mit Hilfe des "Proton Authenticator" für iOS entstanden. Dort kann man die Daten anderer Clients importieren – so diese Clients sie denn rausrücken.



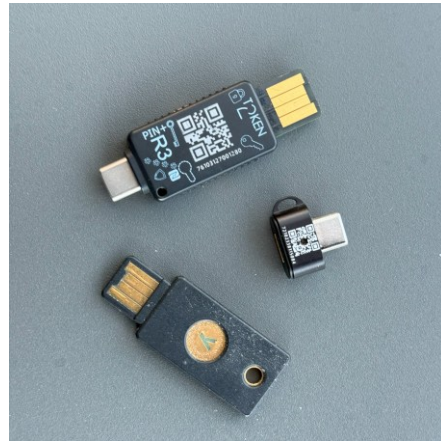
Geschmackssache

Meine persönliche Empfehlung:

<https://proton.me/de/authenticator>

Der Google Authenticator genießt eine Sonderstellung, da er mit Abstand der meist verbreitetste Authenticator ist. Wenn Anwender diesen bereits verwenden, gibt es meines Erachtens keinen Grund, davon abzuraten.

Fido2 security keys



In der zweiten Demo zeige ich die Verwendung eines Fido2 tokens (Token2 PIN+ Mini-C).

Im Bild sind eine Reihe solcher Fido2 tokens zu sehen.

Vielen Dank für die Bereitstellung der Muster geht an:

- NitroKey
- Token2
- Yubico

DEMO 2

Ist für heute wirklich Schluss?



- TOTP = verlässlicher Standard (RFC 6238)
- Microsoft Authenticator app
 - Irreführende Menüführung
 - Proprietäre Erweiterungen
 - Mangelhafte Exportfunktion
- Proton
 - Proton Authenticator (TOTP client)
 - Proton Pass (Passwortmanger)
- Die Zukunft: Passkeys

TOTP ist ein verlässliches,
standardisiertes Verfahren.

Es mag attraktive

Verbesserungen geben,

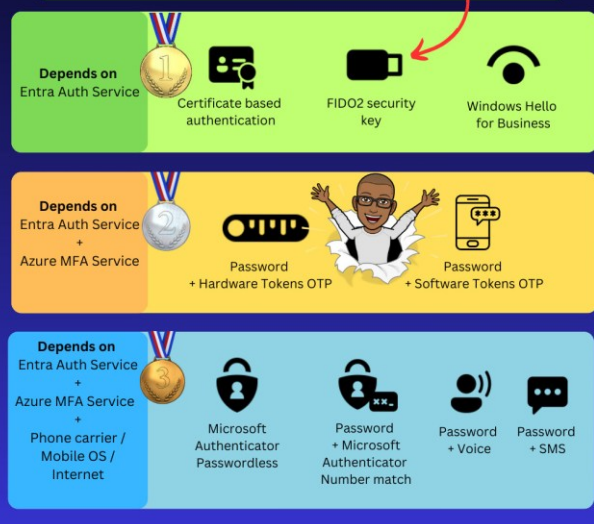
die aber oftmals nur
eingeschränkt verbreitet sind.

What are the most resilient MFA methods?

Folks, the **Azure MFA** enforcement will soon start rolling out and there will be **NO EXCEPTIONS** for **emergency access** accounts!

Here's a quick guide to help you pick the most resilient MFA method for your emergency access accounts 📌

TLDR: Use FIDO2 security key for emergency accounts



Bildnachweis:

https://en.wikipedia.org/wiki/File:Pink_Panther.png

<https://bsky.app/profile/merill.net/post/3kz42mymvru2c>

(oben)

(unten)

Wir danken unseren cim Sponsoren!



Herzlichen Dank an die Sponsoren!

Herzlichen Dank an das gesamte Team der CIM-Lingen!

Wir sehen uns in 2026!

<https://cim-lingen.de/>